

Praxis alignment for adviser review

Gary Pagan | October 4, 2026 | Proposed replacement framing; completed results remain unchanged.

Recommended title

Auditing and Preserving Exfiltration Warnings in a LightGBM APT Detection Pipeline

Problem statement: issue and consequence

In the examined LightGBM APT stage-classification pipeline, a change in how the system selects available evidence increased macro-F1 while reducing the proportion of exfiltration-labeled flows that received any attack warning. Accepting this change on the overall score alone could therefore remove opportunities to investigate suspected data theft. The financial stakes are substantial: IBM (2026) reports a global average data-breach cost of US\$4.99 million. Model review needs to measure retained attack warnings alongside classification scores and the additional review workload of proposed repairs.

The first sentence is supported by our PX-081/PX-106 evidence, not attributed to Uddin et al. The IBM estimate supplies industry context; it is not an APT-specific loss estimate, a cost per missed flow, or a demonstrated saving from this study.

Purpose and thesis

Purpose: develop and evaluate a reproducible review procedure that identifies lost exfiltration warnings, distinguishes warnings discarded by the pipeline from attacks missed by all available models, and measures the benefits and costs of retaining available warnings.

Thesis supported by completed evidence: paired warning accounting and recorded decision traces expose losses that an aggregate score alone does not describe. An OR gate retains every warning produced by its available members, but its detection gain and false-alert cost depend on the data and members. It cannot recover an attack that every member labels benign.

Two wording corrections

F1 does not charge all errors the same price. It combines precision and recall without explicitly representing the operational difference between a wrong attack-stage name and no warning. Also, a model warning is an opportunity for review; this study has not measured whether an analyst actually reviewed it.

Aligned questions and testable claims

These organize completed studies. They are retrospective claims, not newly preregistered hypotheses. Failed tests remain visible; no threshold should be selected after looking at the test results.

RQ1: When does a better score conceal fewer warnings?

Under clean evidence and budget three, does error-focused evidence selection increase macro-F1 while decreasing exfiltration warning recall compared with entropy-based selection, using the same LightGBM experts and test records?

H1: the three-seed mean change in macro-F1 is positive and the mean change in exfiltration warning recall is negative. Completed result: consistent with H1 on UNRAVELED; F1 rises from 0.7148 to 0.7379, while warning recall falls from 85.18% to 76.25%. This is descriptive evidence from one campaign, with substantial seed sensitivity. The original ordering did not replicate on AIT.

RQ2: How much warning recovery does OR provide, and at what cost?

Does the three-member OR gate recover more exfiltration warnings than probability averaging and the best individual member, on UNRAVELED and the separate AIT Wilson and Harrison executions? Count benign false alerts and grouped review cases alongside recall.

H2: OR has strictly higher exfiltration warning recall than the best individual member in both AIT executions. Completed result: not supported. Wilson ties the best member. OR does improve on averaging, including 98.78% versus 68.04% on UNRAVELED, with 196 versus 182 benign false alerts. These are flow counts, not analyst hours or independent incidents.

RQ3: Does added explanation improve diagnosis beyond a trace?

On the predefined pipeline-fault scenarios, does replay-supported explanation diagnose the warning-loss cause more accurately than an ordinary decision trace?

H3: replay-supported explanation has higher diagnosis accuracy than the trace baseline. Completed result: not supported. Both diagnose 170/170 scenarios and classify 510/510 repair-feasibility checks correctly in PX-105. The bot study verifies predefined evidence checks; it does not establish human analyst benefit.

What this means for the proposal

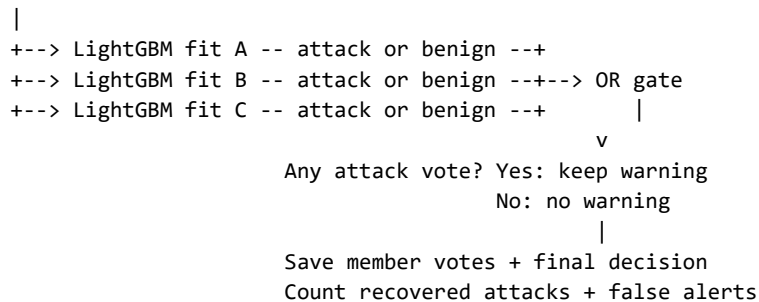
The completed evidence supports an applied audit and a conditional repair. It does not support a superior new explanation algorithm or a repair that consistently beats the strongest model. Hypotheses need not all succeed, but the claimed contribution must fit these outcomes.

Methodology in everyday language

1. Start with recorded network flows and the dataset authors' attack-stage labels. Use UNRAVELED for the examined campaign and adapted AIT Wilson/Harrison for external checks. Keep executions separate; many flows from one execution are not many independent attacks.
2. Train LightGBM classifiers. LightGBM combines many small decision trees: each tree asks questions about traffic measurements, and their combined scores select benign, other attack, movement, or exfiltration. Evidence variants use current traffic measurements, host roles, and/or historical summaries.
3. Prove the score-warning mismatch by replaying two evidence-selection policies on exactly the same test rows. Hold the fitted experts fixed. Count true exfiltration rows that change from any attack label to benign, including those previously given the wrong attack-stage name. Report gains separately from losses.
4. Test the repair using three separately fitted current-traffic-plus-host-role LightGBM models, with seeds 8101, 8102 and 8103. These are different fits of the same architecture, not three independent kinds of evidence. Compare individual models, averaged probabilities and OR on the same rows.
5. Check the recorded decisions. Identify whether a warning existed but was discarded, or whether every available model said benign. Replay only explicitly specified changes. This explains the pipeline decision; it does not prove what caused the attack.
6. Report per-seed results, execution-level results and paired uncertainty using capture groups where supported. Fit thresholds and choose methods on training/calibration data. Already examined test data cannot become a fresh confirmation set. A new claim needs untouched executions and a frozen protocol.

Simple repair diagram

Same network flow



This diagram is the repair comparison. The original score-loss experiment separately compares evidence-selection policies over fixed experts.

Metrics that answer the questions

Macro-F1: overall class performance. Exact-stage recall: exfiltration correctly named. Warning recall: exfiltration given any attack label. Warning losses/gains: paired changes in the same rows. Benign false alerts and grouped cases: workload proxies. Episode coverage: labeled episode proxies with at least one warning. Diagnosis accuracy: correct identification of the injected pipeline fault. No dollar savings, analyst time or prevented breaches were measured.

Novelty assessment and the next decision

Novelty remains unresolved. OR combination, prediction regressions, false-negative diagnosis and SHAP-based intrusion explanations all have prior work. Merely adding explanations, an LLM narrator, or APT data does not establish a new method. The mathematical OR guarantees are established set-union properties; the empirical contribution concerns where the tradeoff is useful.

The strongest current contribution candidate is the combined, reproducible evidence: wrong-stage warnings can disappear into benign predictions; available-warning losses and all-model misses require different repairs; and gains must be reported with false alerts and episode coverage. A targeted search cannot prove that this combination is first. Adviser acceptance of an applied contribution remains necessary.

If a stronger XAI contribution is required

Investigate whether a verifiable explanation helps choose a useful repair under a fixed review-case budget on unseen executions. For each proposed warning, show the supporting model, observed traffic evidence, recorded delivery/selection decision, and the exact change that would restore the warning. If all members are silent, explicitly report that the explanation cannot establish a recoverable warning.

Compare the proposed method against ordinary trace diagnosis, confidence ranking, unconditional OR, a cost-sensitive decision rule and a binary attack detector. Give every method the same case budget and available information. The primary outcome should be additional labeled exfiltration episodes covered at that budget; secondary outcomes should include benign cases, explanation correctness and stability. Freeze the episode definition, budget and success criterion before evaluation.

Proceed only if the proposed explanation changes a decision and beats these baselines on untouched executions. PX-103 already tied confidence ranking and PX-105 tied ordinary traces, so those implementations have not passed this test. Human usefulness would require an approved human study; a bot can test consistency but cannot stand in for SOC operators.

Literature access and evidence limits

GWU Libraries discovery was used on October 4: the CyberShapley title search returned one peer-reviewed Computers & Security record. The catalogue requested sign-in for complete results; authenticated subscription full-text access was not established. CyberShapley and AlertPro full-text review used the previously supplied local PDFs. Additional primary papers and IBM's report landing page were checked openly. This was a targeted overlap review, not a systematic literature review.

No new fits or AWS jobs were needed for this alignment. Existing PX-081, PX-092, PX-103, PX-105 and PX-106 findings are summarized; results and protocols were not rewritten. This brief is an adviser-review supplement, not a replacement for the complete manuscript.

Selected references and their role

IBM. (2026). Cost of a data breach report 2026. <https://www.ibm.com/reports/data-breach>

Role: Financial context only: US\$4.99 million global average.

Uddin, M. A., Aryal, S., Bouadjene, M. R., Al-Hawawreh, M., & Talukder, M. A. (2025). Hierarchical classification for intrusion detection system: Effective design and empirical analysis. *Ad Hoc Networks*, 178, 103982. <https://doi.org/10.1016/j.adhoc.2025.103982>

Role: Related binary/stage classification design; not the source of our LightGBM score-loss result.

Kittler, J., Hatef, M., Duin, R. P. W., & Matas, J. (1998). On combining classifiers. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 20(3), 226-239. <https://doi.org/10.1109/34.667881>

Role: Classifier combination is established.

Malach, A., Wudali, P. N., Momiyama, S., Furukawa, J., Araki, T., Elovici, Y., & Shabtai, A. (2025). CyberShapley: Explanation, prioritization, and triage of cybersecurity alerts using informative graph representation. *Computers & Security*, 150, 104270. <https://doi.org/10.1016/j.cose.2024.104270>

Role: Prior explainable cybersecurity alert triage, including APT datasets.

Wang, X., Yang, X., Liang, X., Zhang, X., Zhang, W., & Gong, X. (2024). Combating alert fatigue with AlertPro: Context-aware alert prioritization using reinforcement learning for multi-step attack detection. *Computers & Security*, 137, 103583. <https://doi.org/10.1016/j.cose.2023.103583>

Role: Prior alert prioritization; its reported comparisons already include higher F1 with lower attack recall.

Mia, M., Pritom, M. M. A., Islam, T., & Hasan, K. (2024). Visually analyze SHAP plots to diagnose misclassifications in ML-based intrusion detection [Preprint]. *arXiv*. <https://arxiv.org/abs/2411.02670>

Role: Prior SHAP-based diagnosis of false positives and false negatives; inspect before claiming a new XAI contribution.

Ficke, E., Schweitzer, K. M., Bateman, R. M., & Xu, S. (2019). Analyzing root causes of intrusion detection false-negatives: Methodology and case study [Preprint]. *arXiv*. <https://arxiv.org/abs/1909.08725>

Role: Prior systematic false-negative root-cause analysis, demonstrated with Snort.